ANCHOR CBS · INSA CYBERSECURITY AUDIT

Document: COMPLIANCE_MATRIX.md · Generated 11 November 2026

INSA Cybersecurity Compliance Matrix

System: CBS General — Web-Based SACCO Core Banking / ERP Back Office
Document ID: CBS-SEC-CM-2026-001
Version: 1.0
Audit date: 11 November 2026
Code baseline: commit `2b23823 (security hardening) + working tree` (branch `hayder-update-FRA`)
Audit basis: INSA Cybersecurity Audit Minimum Requirements, document OF/AEAD/001 — Compliance check list, areas 1–16 (52 checklist rows)
Classification: Internal / Confidential

1. Scope and Method

This assessment covers the web application, REST API, authentication and authorization layer, database schema, audit trail, SMS/OTP integration, and front-end build of the SACCO core banking / ERP back office.

The system is a browser-based back-office platform. It contains no electronic invoice machine, POS terminal, payment-card reader, firmware image, bootloader, TPM/secure element, secure boot, JTAG/UART/SPI interface, OTA update channel, fiscal printer, or physical device enclosure. The 28 checklist rows that target devices, firmware, fiscal invoicing, or card schemes absent from this platform are marked **Not Applicable (N/A)**. **N/A is not a pass and is not evidence of device security.** If certified POS or invoice hardware is later deployed, those rows must be re-assessed against the specific device.

Method: source-code review, configuration review, authenticated and unauthenticated API testing against the running local instance, database trigger inspection, and front-end dependency scanning. Test evidence is reproduced in `security/VULNERABILITY_REPORT.md` §6 and `security/README.md`.

Status legend

Status	Meaning
Compliant	Control is implemented in the platform and was verified by code inspection and/or a live test.
Partial	Control exists but is incomplete, configuration-dependent, or not enforced across the whole requirement.
Gap	Control is absent or not evidenced.
Not Applicable	Requirement targets hardware, firmware, card-scheme, or fiscal-invoicing scope that does not exist in this platform.

Result summary

Status	Count	Share of 52 rows
Compliant	7	13.5%
Partial	12	23.1%
Gap	5	9.6%
Not Applicable	28	53.8%
Total	**52**	**100%**

Of the **24 applicable rows**, 7 are fully compliant (29.2%), 12 are partial (50.0%), and 5 are gaps (20.8%). TLS 1.3 and HTTP→HTTPS are now live and verified; the remaining risk is absent mTLS, no verified encryption at rest or field encryption, no independent penetration test/certification, and residual coarse authorization for PUT/PATCH and SMS/accounting endpoints. The demo password is fixed for production (rotated seed + production guard); old databases with `demo123` hashes still need rotation. The policy pack exists but awaits management sign-off.

2. Compliance Matrix

> Evidence paths are relative to the repository root. Live test results refer to the audit instance on `localhost:8080` over HTTP; HSTS was verified by sending `X-Forwarded-Proto: https`, which the application trusts through `server.forward-headers-strategy: framework`.

Ref	Compliance Area	Requirement	Status	Evidence	Remarks / Remediation
1	Governance & Scope Adherence	Audit covers all devices: ERP, POS, electronic invoice machines, and peripherals to avoid blind spots.	Partial	Full web module inventory in `backend/src/main/java/com/cbs/sacco/**` and `src/pages/**`; scope statement in this document and in `security/VULNERABILITY_REPORT.md` §2; 40+ endpoint groups exercised.	ERP back office is fully in scope. No POS/invoice/peripheral devices exist in this platform. An independent third-party assessment has not been performed.
1.1	Compliance Objective	No critical systems/modules are skipped; all authorized scope is thoroughly tested.	Partial	Code review of all 25 backend packages; local tests of auth, RBAC, audit, validation, headers, CORS; production checks of TLS, headers, auth, RBAC, audit, and dependencies on 11 Nov 2026. Audit-trail verification returned `{"valid":true,...}`.	Every in-scope module was reviewed statically and the deployed perimeter was tested. Not every endpoint was dynamically fuzzed. Full OWASP coverage is open (V-12, V-17).
1.2	Testing Ethics	Testing must not disrupt integrity, availability, or confidentiality; ethical hacking standards followed.	Compliant	Read-only review; non-destructive API requests; dedicated test users; no production data; no denial-of-service or password-spray activity. The lockout test used a single dedicated account and was stopped after the lock response.	No data was altered during testing. Test writes were limited to authentication audit events.
1.3	Documentation	Findings are clearly and accurately documented without false or misleading assurances.	Compliant	This matrix and `security/VULNERABILITY_REPORT.md`; every N/A row is justified; every claimed control cites a file path, live test, or repository inventory.	No certification or hardware compliance is claimed.
2	Secure Boot	Bootloader uses hardware-protected cryptographic keys to verify firmware authenticity before execution.	Not Applicable	Repository and deployment contain no bootloader or firmware. Application is a Spring Boot service on a standard OS.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
2.1	Secure Boot	Device halts boot if firmware verification fails, preventing tampered firmware execution.	Not Applicable	No bootloader/firmware component exists.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
2.2	Secure Boot	Attempts to bypass secure boot (e.g., glitching) are detected and logged.	Not Applicable	No boot ROM, secure boot chain, or tamper sensor exists.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
3	Firmware & Software Integrity	Firmware on the device is encrypted with AES-256 or better to prevent extraction.	Not Applicable	No firmware image or device storage exists.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
3.1	Firmware & Software Integrity	Firmware is digitally signed and the signature is validated during boot.	Not Applicable	No firmware signing or boot-time verification code.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
3.2	Firmware & Software Integrity	Cryptographic keys are stored in tamper-resistant hardware such as TPM or Secure Element.	Not Applicable	No TPM/SE integration; JWT signing key is held in process memory from an environment variable.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
4	Hardware Security	Debug ports (UART, JTAG, SPI) are disabled	Not Applicable	No physical device, board, or debug interface.	No such device is part of this web platform; applies to certified

Ref	Compliance Area	Requirement	Status	Evidence	Remarks / Remediation
		or strictly access-controlled.			POS/invoice hardware if deployed.
4.1	Hardware Security	Sensors detect physical tampering (e.g., case opening) and log it for audit.	Not Applicable	No enclosure or tamper sensor.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
4.2	Hardware Security	Sensitive chips/components are protected with shielding, epoxy, or equivalent.	Not Applicable	No hardware components under the organization's control.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
5	Data Security	Fiscal and sensitive data are encrypted on storage to protect against theft or device loss.	Partial	`V1__baseline.sql` stores `fayda_id`, `phone`, and `email` as plaintext columns; `application.yml` has no encryption properties; no PostgreSQL TDE/volume-encryption configuration is in the repository.	Encryption at rest is delegated to infrastructure and is not evidenced. Enable encrypted volumes/TDE and application-level field encryption (V-11).
5.1	Data Security	Sensitive fields (e.g., taxpayer ID) are never stored plaintext; they are encrypted or masked.	Partial	Passwords are BCrypt-hashed (`SecurityConfig.passwordEncoder`). `member.fayda_id`, `member.phone`, and `member.email` are plaintext in `V1__baseline.sql`. Audit redaction covers password/secret/token fields only (`AuditTrailEventListener.isSensitive`), not Fayda ID or phone. `GET /api/sms/logs` returns full phone numbers to any authenticated reader.	Implement AES-GCM field encryption or tokenization for Fayda ID/phone; mask in UI, exports, audit views, and SMS logs; extend audit redaction (V-11, O-06).
5.2	Data Security	Defined retention periods and secure deletion compliant with legal/regulatory requirements.	Partial	`security/policies/05_Data_Retention_and_Deletion_Policy.md` now defines retention periods (members 5 years after exit; financial/loan/audit 7 years; SMS 12 months; backups 90 days), legal holds, secure deletion, and deletion logging. The approval/sign-off table is blank, and no automated purge/anonymization job or deletion log is implemented in the application.	Management sign-off, then implement scheduled purge/anonymization, deletion verification, and backup expiry; retain evidence. Policy existence alone is not proof of operation (V-13).
6	Secure Communication	All data in transit is encrypted with TLS 1.3 or newer.	Compliant	**Live production:** `https://51-222-143-50.sslip.io` negotiates `TLSv1.3` / `TLS_AES_256_GCM_SHA384`; Let's Encrypt certificate CN= `51-222-143-50.sslip.io`, valid 2026-11-10 to 2027-02-08. HTTP returns `301` to HTTPS. HSTS `max-age=31536000; includeSubDomains`. Verified 11 Nov 2026.	TLS 1.3 is deployed and externally verified. Certificate renewal and cipher policy must be monitored; mTLS is a separate gap (6.1).
6.1	Secure Communication	Mutual TLS authenticates both client and server to prevent MITM.	Gap	Production is TLS 1.3 only, but there is no client-certificate request/verification in the deployed nginx site, `application.yml`, `SecurityConfig.java`, or the SMS client. The live endpoint is server-authenticated only.	Implement mTLS for service-to-service links and any future ERP–POS connector; browser-to-API mTLS is optional and operationally costly (V-10 Partial).
6.2	Secure Communication	Insecure legacy protocols (HTTP, FTP, Telnet) are disabled.	Compliant	**Live production:** `http://51-222-143-50.sslip.io` returns `301 Moved Permanently` to the HTTPS URL; nginx serves only TLS 1.3 on 443. No FTP/Telnet service is part of the platform.	HTTP is redirected, not served. Firewall/port-80 policy should still be documented; HSTS is present on HTTPS responses.
7	Access Control	Multi-factor authentication adds a layer beyond passwords.	Partial	**Live production:** `REQUIRE_MFA=true`; teller login returns `200` (role does not require MFA); manager and admin return `202 {"mfaRequired":true}` and an SMS OTP is sent to the verified phone `+251932123090`. SMS OTP uses 5-minute TTL, 5 attempts, resend throttling (`SmsService`).	MFA is enabled for privileged roles, but teller is not required, `REQUIRE_MFA` is configuration-dependent, and enrolment/reset/recovery remain manual (V-14). Not full coverage of all users (V-09 Partial).
7.1	Access Control	Sessions time out after inactivity and accounts lock after repeated failed logins.	Compliant	JWT TTL is 1,800 s (`application.yml`); a local token decoded to `ttl_seconds=1800`. Front end idle logout is 30 minutes (`src/context/AuthContext.tsx`, `SESSION_IDLE_MS`). Lockout after 5 failures for 15 minutes (`AuthService`); local test 5× `401` then `423`. Production runs the same build; the live JWT TTL was not independently decoded.	Lockout is per-user and in-process; there is no distributed/IP throttle or CAPTCHA. A stolen token remains valid until expiry; browser token storage is exposed to XSS (V-18).
7.2	Access Control	Permissions are assigned strictly by role, enforcing least privilege.	Partial	**Live production:** teller/manager `GET /api/auth/users` `403`, admin `200`; auditor write `403`; teller `POST /api/gl-rules` and `/api/compliance/policy` `403`; accountant `POST /api/gl-rules` `400` (allowed validation). `SecurityConfig.java` has fine-grained POST rules for GL, compliance, notifications, expenses/bank/charges/product-types,	Still partial: no `@PreAuthorize` / `@Secured`; PUT/PATCH rules remain broad; `/api/sms/**`, `/api/accounting/journal`, and some other POSTs remain

Ref	Compliance Area	Requirement	Status	Evidence	Remarks / Remediation
				savings product/interest/fees, loan lifecycle, shares, approvals, dormancy, and checkoff.	reachable by any non-AUDITOR role. Extend the role matrix (V-16 Partial).
8	Provisioning & Key Management	Keys are securely injected during manufacturing using HSMs or equivalent.	Not Applicable	No manufacturing or device-provisioning process.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
8.1	Provisioning & Key Management	Each device has unique cryptographic keys, avoiding shared/default keys.	Not Applicable	No device fleet or per-device keys.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
8.2	Provisioning & Key Management	Mechanisms exist to securely rotate or revoke keys if compromised.	Not Applicable	Device key rotation does not apply. Note: the JWT signing secret is rotated manually by replacing `JWT_SECRET` and restarting; no automated rotation.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed. Web signing-key rotation is a separate operational procedure (V-06).
9	OTA Update Security	Over-the-air updates are signed and encrypted.	Not Applicable	No OTA client, update server, or device firmware.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
9.1	OTA Update Security	Device verifies update version and blocks downgrade attacks.	Not Applicable	No firmware update mechanism.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
9.2	OTA Update Security	Prevents reinstallation of older vulnerable firmware.	Not Applicable	No anti-rollback storage or firmware version policy.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
9.3	OTA Update Security	All update events (installations, failures) are logged for accountability.	Not Applicable	No OTA update events exist. Software deployments are not centrally logged in the application.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed. CI/CD deployment logging is recommended.
10	Device Lockdown	Only vendor-approved software can run on the device.	Not Applicable	The platform is browser-delivered; there is no managed endpoint or installed device application.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
10.1	Device Lockdown	Command-line interfaces are disabled or restricted unless explicitly required.	Not Applicable	No device CLI or shell is exposed by the application. Server OS hardening is the hosting provider's responsibility.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
10.2	Device Lockdown	Users and processes have only the minimal privileges necessary.	Partial	Six application roles exist (`V2__seed.sql`); fine-grained POST gates are live for finance, compliance, shares, loans, approvals, dormancy, and checkoff. Backend runs as a systemd service bound to `127.0.0.1:8081` ; no OS service-account review, database least-privilege review, or container hardening evidence is included. PUT/PATCH and SMS/accounting writes remain broad (V-16 Partial).	Document OS/DB service accounts; run the API as a non-root user; grant the application DB role only required DML; split migration and runtime DB users; finish endpoint-level authorization.
11	Fiscal Data Protection	Invoice logs are WORM and digitally signed to prevent modification.	Not Applicable	No invoicing, fiscal printer, or invoice log. The platform has an append-only, hash-chained `audit_trail` ; `V29__audit_log_immutable.sql` now adds an append-only trigger to the legacy `audit_log` as well.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed. The `audit_trail` hash chain is an analogous control, not fiscal-invoice compliance. `audit_log` is now append-only but not hash-chained (V-19 Fixed; retire or reconcile).
11.1	Fiscal Data Protection	Transactions and logs are	Not Applicable	No fiscal invoice records. Audit entries use server UTC time (`Instant.now()`); no RFC 3161 trusted timestamp authority.	No such device is part of this web platform; applies to certified

Ref	Compliance Area	Requirement	Status	Evidence	Remarks / Remediation
		timestamped from a trusted time source.			POS/invoice hardware if deployed. Use NTP and, if required, RFC 3161 for audit exports.
11.2	Fiscal Data Protection	Offline invoice data is encrypted and synchronized when connectivity returns.	Not Applicable	No offline invoice cache or store-and-forward client.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
12	ERP–POS Integration Security	APIs between ERP and POS use OAuth2 or JWT with TLS 1.3+ encryption.	Partial	**Live:** JWT (HS256) issued by `JwtService`, validated by `JwtAuthFilter`; TLS 1.3 at `https://51-222-143-50.sslip.io`; CORS locked to that origin. No POS/ERP connector exists, and mTLS is absent.	JWT and TLS 1.3 are live for the web API. There is no POS integration to assess; add mTLS and signed requests before any POS/ERP connector (V-10 Partial).
12.1	ERP–POS Integration Security	All user and system inputs are strictly validated and sanitized to prevent injection and other attacks.	Partial	Negative savings amount rejected `400` (`SavingsService.transact`, live test); SQL-injection login payload returned `401` with a generic message (live test); Spring Data JPA repositories use parameterized queries. However, there are **0** `@Valid` usages and **107** `Map<String,Object>` request-body parameters; validation is hand-written and endpoint-specific.	Introduce validated DTOs with Bean Validation, a global error contract, allow-lists for enums, and automated fuzzing/OWASP ZAP tests (V-17).
12.2	ERP–POS Integration Security	Operational, financial, and administrative roles are separated to minimize fraud risk.	Partial	**Live:** roles ADMIN, MANAGER, TELLER, CREDIT_OFFICER, ACCOUNTANT, AUDITOR; admin paths restricted; auditor writes `403`; teller GL/compliance writes `403`; accountant GL allowed (`400` validation). PUT/PATCH, SMS, and accounting journal writes remain broad.	Role separation is substantially improved but not complete. Extend the role matrix to PUT/PATCH, `/api/sms/**`, and `/api/accounting/**`; add method-level tests (V-16 Partial).
13	Physical Security	Devices have tamper-evident seals and custody logs.	Not Applicable	No organization-controlled POS/invoice devices or custody log.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
13.1	Physical Security	Systems alert or wipe/shutdown on tampering.	Not Applicable	No device tamper detection or remote wipe.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
13.2	Physical Security	Backup power and surge protection prevent damage or data loss.	Not Applicable	No device power supply. Server-room power is a hosting-provider control.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
14	Testing & Validation	Realistic penetration tests simulate attacker behavior before exploitation.	Gap	No independent penetration-test report or scope letter exists. The assessment used code review and targeted API tests, not an adversarial full-scope test.	Commission an external penetration test (network, API, web, authenticated multi-role) before production and annually; remediate and retest (V-12).
14.1	Testing & Validation	Firmware is reverse-engineered and analyzed for backdoors/flaws.	Not Applicable	No firmware to analyze.	No such device is part of this web platform; applies to certified POS/invoice hardware if deployed.
14.2	Testing & Validation	APIs are tested against OWASP Top 10, including injection and broken authentication.	Partial	`security/evidence/security-test-results.md` plus live production checks on 11 Nov 2026 record broken authentication (401/423/202), broken access control (403), injection (SQLi `401`), input validation (negative amount `400`), TLS/headers, CORS, audit integrity, and dependency scan. No automated ZAP/Burp full scan, no fuzzing, and no rate-limit test beyond OTP code inspection.	Add ZAP baseline/full scans to CI, an authentication/authorization matrix, and abuse-case tests (V-12, V-17).
15	Standards Compliance	PCI-DSS is met for all payment-card data handled.	Not Applicable	No PAN, CVV, track data, card-reader, or card-acquiring module. Payments are cash, bank, check-off, and internal transfer.	No card data is stored, so PCI-DSS scope is reduced. Do not add card data without a PCI-DSS program (V-13).
15-NP	Standards Compliance	Non-PCI proprietary card systems (loyalty, voucher, wallet, local cards) meet	Not Applicable	No loyalty/voucher/wallet card or stored-value card module.	No such system is part of this platform. Reassess if a proprietary card scheme is added. The source checklist numbers this row "15" a second

Ref	Compliance Area	Requirement	Status	Evidence	Remarks / Remediation
		equivalent standards.			time; `15-NP` is used here for traceability.
15.1	Standards Compliance	ISO/IEC 27001 ISMS policies and controls are audited and implemented.	Gap	A 13-document policy pack now exists (`security/policies/` and `security/ANCHOR_CBS_SECURITY_POLICIES.pdf`) covering access, incident response, BCP/backup, retention, vendor, risk, change, logging, and physical security. The pack explicitly claims no ISO certification; signatures are pending, and there is no ISMS scope, Statement of Applicability, risk register, internal audit, or certificate.	Obtain management sign-off; build the ISMS scope/SoA/risk register; run internal audit and management review; then certify (V-13).
15.2	Standards Compliance	ISO/IEC 15408 Security Functional and Assurance Requirements are validated under Common Criteria.	Gap	No Security Target, protection profile, EAL evaluation, or certificate.	Engage a Common Criteria laboratory only if product certification is a contractual/regulatory requirement; otherwise adopt an equivalent secure-development baseline (V-13).
15.3	Standards Compliance	The system complies with national fiscal regulations, including invoicing and audit requirements.	Not Applicable	No invoicing, fiscal printer, or fiscal receipt module. The platform records SACCO transactions and an audit trail, not tax invoices.	No such device/function is part of this platform. If used for fiscal invoicing, obtain local fiscal-authority certification before deployment.
16	Audit Deliverables	Detailed vulnerability report includes proof-of-concept exploits and CVSS severity scores.	Compliant	`security/VULNERABILITY_REPORT.md` : 19 findings (10 fixed, 4 partial, 5 open), CVSS v3.1-style vectors/scores, affected components, request-level evidence, remediation status, a 2026-11-11 remediation-update table, and a live-deployment evidence section.	Exploits are documented as reproducible requests, not weaponized code. Scores are estimated, not scanner-generated.
16.1	Audit Deliverables	Completed checklist cross-referenced with industry standards to demonstrate coverage.	Compliant	This matrix: all 52 rows, status, file/test evidence, cross-references to V-01–V-19, live production evidence, and the policy pack; maps to INSA OF/AEAD/001 and OWASP/ISO/PCI scope notes.	Source checklist has a numbering anomaly at area 12 (`12.` then `12.1`); normalized here as 12.1 (input validation) and 12.2 (role separation).
16.2	Audit Deliverables	Relevant certifications (e.g., ISO 27001, PCI-DSS) are submitted or in process.	Gap	No ISO 27001, ISO 15408, or PCI-DSS certificate or certification project evidence. The 13-policy pack is a management-system input, not a certificate; it explicitly states that no ISO certification is claimed.	Provide a certification roadmap and executive sponsorship; see V-13. No certificate is claimed.

3. Notes on Interpretation

1. **N/A is not compliance.** The 28 rows targeting device, firmware, fiscal-invoice, or card-scheme controls are outside the architecture. They become applicable only if the SACCO deploys certified POS, invoice, or card systems.
2. **Configuration-gated controls.** MFA (`REQUIRE_MFA`), HTTPS redirect (`REQUIRE_HTTPS`), and CORS (`CORS_ORIGINS`) are environment-driven. Production must set them explicitly; defaults are development values.
3. **Live evidence.** HTTP results were observed on 10–11 November 2026 against the local instance and the live production deployment at `https://51-222-143-50.sslip.io`; they are recorded in `security/evidence/security-test-results.md` and `security/VULNERABILITY_REPORT.md` §7. Audit-trail length (`checked:58` in the local run) will grow; the live verify returned `valid:true` without a fixed count.
4. **Test-suite caveat.** The pre-existing integration tests and `scripts/api-smoke.sh` still send the legacy passwordless login payload and therefore do not reflect the remediated authentication contract. They must be updated before being used as release evidence (`security/README.md` §6).
5. **Numbering normalization.** The source checklist prints `2,2` (normalized here to `2.2`), numbers the area-12 rows `12.` and `12.1` (normalized to `12.1` input validation and `12.2` role separation), and numbers the second area-15 row `15` again (referenced here as `15-NP`, non-PCI proprietary cards). These changes are for traceability only.
6. **No false certification.** This document does not assert INSA certification, ISO certification, PCI-DSS compliance, Common Criteria evaluation, or device compliance.

Prepared as part of the INSA cybersecurity audit engagement. Companion documents: `security/VULNERABILITY_REPORT.md`, `security/SRS.md`, `security/README.md`.